



capture this requirement.

how do i input the requirement for this:

Organisation Risk Score = your environment-specific assessment

Captured requirement:

Organisation Risk Score = your environment-specific assessment

To input this requirement properly, treat it as a **separate contextual risk score**, not as a replacement for the official NVD or vendor CVSS score.

Recommended requirement wording

Use the following in your requirements or system specification:

The system shall calculate and record an **Organisation Risk Score** representing the organisation's environment-specific assessment of a vulnerability. This score shall consider contextual factors such as asset criticality, exposure, exploitability within the organisation's environment, compensating controls, affected data, business impact, and the organisation's risk tolerance.

The Organisation Risk Score shall be stored separately from the official NVD CVSS Base Score and vendor-reported severity. The LLM may collect evidence and recommend contextual inputs, but the final score shall be calculated using a defined and repeatable scoring model.

Suggested input fields

You can define the requirement using fields like these:

Field	Example input
CVE ID	CVE-2025-37164
NVD CVSS Base Score	10.0
Vendor CVSS Score	9.8
Affected asset	Production API server
Asset criticality	High
Internet exposure	No; private subnet
Exploit available	No confirmed exploit

Field	Example input
Vulnerable service enabled	Yes
Authentication required	Yes
Compensating controls	Security groups, WAF, network segmentation
Sensitive data affected	Customer information
Organisation Risk Score	6.5
Organisation Risk Rating	Medium
LLM explanation	Contextual reasoning
Evidence	Trivy, NVD, vendor advisory, configuration evidence
Human approval	Required

Example scoring instruction for the LLM

You could provide the following prompt or requirement:

Determine the Organisation Risk Score for the identified vulnerability.

Do not replace or modify the official NVD CVSS Base Score.

Assess the vulnerability based on the organisation's actual environment.

Consider the following factors:

1. Asset criticality.
2. Network exposure.
3. Whether the vulnerable component or service is enabled.
4. Exploit availability and exploit maturity.
5. Authentication and access requirements.
6. Confidentiality, integrity, and availability impact.
7. Existing compensating controls.
8. Business and regulatory impact.
9. The organisation's risk tolerance.

The LLM shall:

- Extract and justify each contextual input.
- Identify the evidence used.
- Explain any difference between the NVD score, vendor score, and Organisation Risk Score.
- Avoid inventing unsupported values.
- Return a recommendation for the contextual inputs.
- Mark the result as requiring human approval.

The final Organisation Risk Score shall be calculated by a deterministic scoring function.

Example output

```
{
  "cve_id": "CVE-2025-37164",
  "nvd_cvss_base_score": 10.0,
  "vendor_cvss_score": 9.8,
  "organisation_risk_score": 6.5,
  "organisation_risk_rating": "Medium",
  "contextual_factors": {
    "asset_criticality": "High",
    "network_exposure": "Private subnet",
    "service_enabled": true,
    "authentication_required": true,
    "exploit_available": "No confirmed exploit",
    "compensating_controls": [
      "Security groups",
      "Network segmentation",
      "WAF monitoring"
    ],
    "sensitive_data_affected": true
  },
  "llm_explanation": "The vulnerability has a Critical technical severity according",
  "evidence": [
    "NVD vulnerability record",
    "Vendor advisory",
    "Trivy scan result",
    "Cloud security-group configuration"
  ],
  "human_review_required": true
}
```

The source document also recommends keeping the NVD CVSS Base Score, vendor score, **Organisation Risk Score**, and **LLM explanation** as separate fields. It specifically suggests that the LLM should justify contextual inputs while a deterministic program performs the actual score calculation.^[1]

A concise requirement statement would therefore be:

The system shall produce an Organisation Risk Score based on the organisation's environment-specific exposure, asset criticality, exploitability, business impact, and compensating controls. The score shall be calculated using a documented deterministic method, stored separately from official CVSS scores, supported by evidence, and subject to human approval.

for this framework.

how should we get the option for Organisation to input?

For this framework, the organisation should not directly type an arbitrary **Organisation Risk Score** such as 6.5. Instead, provide structured input options about the organisation's environment. The framework then calculates the score consistently.

Recommended input design

Use a four-stage process:

1. The organisation provides environment-specific information.
2. The LLM analyses the information and requests missing evidence.
3. A deterministic scoring engine calculates the Organisation Risk Score.
4. A human reviewer approves or overrides the result with justification.

This follows the framework principle that the LLM should collect and explain contextual inputs, while the actual score should be produced by a repeatable rules-based calculator.^[3]

Organisation input form

1. Affected asset

Ask the organisation to identify the affected asset.

```
Asset name:
Asset type:
Environment:
Business owner:
Technical owner:
Deployment location:
```

Recommended options:

- Production.
- Staging or pre-production.
- Development.
- Test or laboratory.
- Disaster recovery.
- Corporate or internal system.
- Customer-facing system.

The organisation should also be able to select the asset from an imported inventory, such as a CMDB, cloud inventory, SBOM, or Trivy scan result.

2. Asset criticality

Use a dropdown or radio-button field:

How important is the affected asset to the organisation?

Options:

Value	Description
1 — Low	Non-critical system with limited business impact
2 — Moderate	Supports internal activities but has available alternatives
3 — High	Supports important business operations
4 — Very high	Major operational, financial, or customer impact
5 — Critical	Essential service, regulated system, or safety-critical function

The organisation should be required to provide a short justification and, where possible, select a business service or asset classification.

3. Network exposure

Ask how the vulnerable component can be reached:

What is the network exposure of the vulnerable component?

Options:

- Directly exposed to the public internet.
- Exposed through an internet-facing application or API.
- Accessible through a VPN or zero-trust gateway.
- Accessible from the corporate network.
- Accessible only from a restricted internal subnet.
- Isolated from the network.
- Exposure is unknown.

This is one of the most important organisation-specific inputs because the same CVE may represent very different risks on an internet-facing server and an isolated internal system.

4. Vulnerable component status

Ask whether the vulnerable component is actually usable in the environment:

What is the operational status of the vulnerable component?

Options:

- Installed and actively used.
- Installed but used only by a limited service.
- Installed but not currently used.
- Disabled.
- Present only in a development or test image.
- Removed but still detected by the scanner.
- Status unknown.

This prevents the framework from treating every detected package as an equally exploitable vulnerability.

5. Exploitability in the organisation

Ask for contextual exploit information:

Is the vulnerability exploitable in this environment?

Options:

- Confirmed exploitable in this environment.
- Exploit is publicly available and conditions appear applicable.
- Exploit is publicly available but environmental conditions are uncertain.
- Exploit is not publicly available.
- Exploitation requires privileged access that is not normally available.
- Exploitation is blocked by architecture or configuration.
- Unknown.

You can separately record the evidence source:

- Internal penetration test.
- Incident or exploitation telemetry.
- Threat-intelligence report.
- Vendor advisory.
- Proof of concept.
- Security testing.
- Analyst assessment.

6. Existing controls

Use a multi-select field:

Which controls reduce the likelihood or impact of exploitation?

Options:

- Web application firewall.
- Network segmentation.
- Security groups or firewall rules.
- Private subnet isolation.
- Strong authentication.
- Privileged-access management.
- Endpoint detection and response.
- Runtime protection.
- Intrusion detection or prevention.
- Secrets management.
- Data encryption.
- Application allowlisting.
- Virtual patching.
- Monitoring and alerting.
- Backups and recovery controls.
- No effective compensating control.
- Control status is unknown.

For every selected control, include:

Control owner:
Control status:
Evidence location:
Last validation date:

Do not automatically give full credit for a control merely because the organisation selects it. The framework should distinguish between:

- Implemented and recently validated.
- Implemented but not recently validated.
- Partially implemented.
- Planned.
- Unknown.

7. Business impact

Ask the organisation to assess the consequences if exploitation succeeds:

Impact area	Input options
Confidentiality	None, Low, Moderate, High, Critical
Integrity	None, Low, Moderate, High, Critical
Availability	None, Low, Moderate, High, Critical
Regulatory impact	None, Possible, Likely, Confirmed
Customer impact	None, Limited, Significant, Severe

|

✱✱

how to do we this. The organisation provides environment-specific information -> allow chat? how do we input this ?

Yes—allow the organisation to provide environment-specific information through a **guided chat interface**, but do not let the chat directly invent or decide the Organisation Risk Score. The chat should collect structured answers, request evidence where necessary, and pass approved inputs to a deterministic scoring engine.

Recommended workflow

```
CVE or vulnerability detected
↓
System retrieves NVD/vendor technical data
↓
Chat asks organisation-specific questions
↓
Organisation provides answers and evidence
↓
LLM converts answers into structured fields
↓
User reviews and confirms the fields
↓
Rules engine calculates Organisation Risk Score
↓
LLM generates explanation and remediation advice
```

The source document supports this separation: the LLM can collect and justify contextual inputs, while a deterministic program calculates the score. ^[4]

Chat input design

Instead of asking the organisation to enter a score directly, ask questions such as:

Asset and business context

1. What asset or application is affected?
2. What is the asset's business criticality?
 - Critical
 - High
 - Medium
 - Low
3. Does the asset process sensitive, personal, financial, or regulated data?
4. What would be the business impact if the asset were compromised?
 - Severe
 - Significant
 - Limited
 - Minimal

Exposure and exploitability

5. Is the vulnerable service exposed to the public internet?
6. Is the service accessible from an untrusted network?
7. Is authentication required to exploit the vulnerability?
8. Is the vulnerable component enabled and actively used?
9. Is there a known public exploit or active exploitation?

Existing controls

10. What compensating controls protect the asset?
 - Network segmentation
 - Security groups
 - WAF
 - EDR
 - Privileged access management
 - Monitoring and alerting
 - None
11. Has exploitation been blocked or detected by an existing control?
12. Is a patch, upgrade, workaround, or configuration change available?

Operational status

13. Is the affected system production, staging, development, or test?
14. Is the vulnerable service currently disabled?
15. How quickly can the organisation apply remediation?
16. Are there regulatory or contractual requirements affecting this asset?

Example chat interaction

```
System: The vulnerability affects an API service. Is the affected service exposed to
Organisation: No. It is deployed in a private AWS subnet and can only be accessed th
System: Is authentication required to access the vulnerable function?
Organisation: Yes. Requests require authentication through the internal API gateway.
System: What is the criticality of the affected asset?
Organisation: High. It supports customer account management but is not responsible fo
System: What compensating controls are in place?
Organisation: Security groups, network segmentation, AWS WAF, CloudTrail logging, and
System: Does the system process sensitive or regulated data?
Organisation: Yes. It processes customer identity information.
System: Please confirm the extracted assessment before scoring:

- Internet exposure: No
- Network location: Private subnet
- Authentication required: Yes
- Asset criticality: High
- Sensitive data processed: Yes
- Compensating controls: Security groups, segmentation, WAF, logging, EDR

Is this information correct?
```

The organisation should confirm the extracted information before the system calculates the score.

Internal structured representation

The chat answers should be converted into a structured object such as:

```
{
  "asset_id": "customer-account-api-prod",
  "environment": "production",
  "asset_criticality": "high",
  "internet_exposed": false,
  "untrusted_network_access": false,
  "authentication_required": true,
  "vulnerable_component_enabled": true,
  "known_exploit": false,
  "sensitive_data": true,
  "business_impact": "significant",
  "compensating_controls": [
    "network_segmentation",
    "security_groups",
```

```

    "waf",
    "cloudtrail_logging",
    "edr_monitoring"
  ],
  "patch_available": true,
  "user_confirmed": true,
  "evidence": [
    {
      "type": "cloud_configuration",
      "reference": "AWS account configuration record"
    },
    {
      "type": "asset_inventory",
      "reference": "CMDB asset record"
    }
  ]
}

```

This object—not the free-text conversation—should be sent to the scoring engine.

Deterministic scoring model

For example, define a simple weighted model:

[Organisation Risk Score

Technical Severity

+

Exposure

+

Asset Criticality

+

Business Impact

Compensating Controls

]

A practical implementation could assign points as follows:

Factor	Example score
CVSS severity: Critical	4
Internet exposed	+3
No authentication required	+2
Known public exploit	+3
Critical asset	+3

Factor	Example score
Sensitive data affected	+2
Strong compensating controls	-2
Vulnerable service disabled	-3

Then map the total to a rating:

Total score	Organisation rating
0-3	Low
4-6	Medium
7-9	High
10 or above	Critical

For the example above:

```

Technical severity      4
Internet exposure      0
Authentication required 0
Known exploit          0
Asset criticality       2
Sensitive data          2
Compensating controls  -2
-----
Organisation Risk Score 6
Organisation Risk Rating Medium

```

The exact weights and thresholds should be defined by the organisation and approved by its risk owner. The important point is that the score is repeatable and auditable.

Suggested system requirement

You can write the requirement like this:

The system shall provide a guided conversational interface through which an organisation can submit environment-specific information about an affected asset or vulnerability. The interface shall collect information relating to asset criticality, network exposure, authentication, exploit availability, data sensitivity, business impact, compensating controls, remediation status, and deployment environment.

The system shall convert the organisation's responses into structured contextual assessment fields. The organisation shall be able to review, correct, and confirm these fields before they are used for scoring.

The system shall calculate the Organisation Risk Score using a documented deterministic scoring model. The LLM shall not independently assign the final score. The system shall retain the original responses, structured inputs, evidence references, calculation details, user confirmation, and generated explanation for audit purposes.

Recommended user interface

Use three components:

1. Chat panel

Collects environment-specific information conversationally.

2. Assessment form or side panel

Displays the extracted fields, for example:

```
Internet exposure: No
Asset criticality: High
Authentication required: Yes
Sensitive data: Yes
Compensating controls: 5 identified
```

3. Review and calculate button

The score is calculated only after the organisation confirms:

```
[ ] I confirm that the above environment information is accurate.
[Calculate Organisation Risk Score]
```

The resulting report should show both scores separately:

```
NVD CVSS Base Score: 10.0 – Critical
Vendor Score: 9.8 – Critical
Organisation Risk Score: 6.0 – Medium
```

The explanation can then state why the scores differ, for example:

The technical severity is Critical because the vulnerability can cause significant impact. The organisation-specific score is Medium because the affected service is isolated in a private subnet, requires authentication, and is protected by network controls. The rating remains subject to confirmation that these controls are active and effective.

✱✱

do a mock up on how we can integrate this

Creating a workable telecom network mockup

instead of organisaition sending text, give the option of yes and no

Creating a Yes/No option mockup

how do we determine the score for the yes/no question

Use each Yes/No answer as a deterministic scoring input. Do not let the LLM decide that “Yes” automatically means a particular risk value without a predefined rule.

There are two good approaches:

- 1. Preferred: map the answers to CVSS Environmental metrics.
- 2. Simpler prototype: use a transparent weighted Organisation Risk Score.

CVSS Environmental metrics are specifically intended to represent characteristics unique to an organisation’s environment, including asset importance and environmental impact requirements. [\[5\]](#) [\[6\]](#)

Option 1: Use CVSS Environmental Scoring

If you want your result to remain compatible with CVSS, map the questions to CVSS v3.1 Environmental metrics.

Yes/No question	CVSS-related input
Is the service internet exposed?	Modified Attack Vector
Is authentication required?	Modified Privileges Required or Attack Complexity, depending on the vulnerability
Is user interaction required?	Modified User Interaction
Does it process sensitive data?	Confidentiality Requirement
Can an attacker modify data?	Integrity Requirement
Could the service become unavailable?	Availability Requirement
Is the asset business-critical?	Confidentiality, Integrity, and Availability Requirements
Are compensating controls present?	Modified Environmental metrics, where they change exploitability or impact

For example:

Internet exposed?	No
Authentication required?	Yes
Sensitive data?	Yes
Production asset?	Yes
Criticality?	High

These answers should not simply be added as points. They should be translated into appropriate CVSS Environmental values and processed using the official CVSS calculator. The resulting value can be called:

Organisation Environmental CVSS Score

If you change the CVSS formula or introduce additional business rules, label the result:

Organisation Risk Score — CVSS-informed

Do not call it an official CVSS score unless it follows the CVSS specification.

Option 2: Weighted Yes/No model

For a simpler and more controllable system, define a score for each question.

Example scoring table

Question	If Yes	If No	Rationale
Is the vulnerable service internet exposed?	+3	0	Public exposure increases attack likelihood
Is the vulnerable component enabled?	+2	0	A disabled component is less likely to be exploitable
Is authentication not required?	+2	0	Unauthenticated exploitation increases risk
Is a public exploit available?	+3	0	Exploit availability increases likelihood
Is the asset in production?	+2	0	Production systems have operational impact
Does it process sensitive data?	+2	0	Data exposure increases impact
Is the asset business-critical?	+3	+1	Critical assets cause greater business impact
Are effective compensating controls present?	-2	0	Controls can reduce residual risk
Is a patch or mitigation available?	-1	0	Available remediation reduces residual exposure

For questions where No represents higher risk, invert the scoring logic. For example:

```
Is authentication required?  
Yes = 0  
No  = +2
```

This is clearer than asking “Is authentication not required?” because the organisation can answer the normal operational question.

Example calculation

Assume the organisation answers:

```
Internet exposed?      No  
Component enabled?    Yes  
Authentication required? Yes
```

Public exploit available?	No
Production asset?	Yes
Sensitive data?	Yes
Business-critical?	High
Compensating controls present?	Yes
Patch available?	Yes

The calculation could be:

Internet exposed:	0
Component enabled:	+2
Authentication required:	0
Public exploit available:	0
Production asset:	+2
Sensitive data:	+2
High business criticality:	+3
Compensating controls:	-2
Patch available:	-1

Total:	6

The mapping could be:

Score	Rating
0-3	Low
4-6	Medium
7-9	High
10-12	Critical

Therefore:

Organisation Risk Score: 6
Organisation Risk Rating: Medium

The official technical score remains unchanged:

NVD CVSS Base Score: 10.0 – Critical
Organisation Risk Score: 6.0 – Medium

This distinction is important because the NVD Base Score describes intrinsic vulnerability characteristics, while the environmental assessment reflects the organisation's deployment and controls.^{[7] [5]}

Recommended interface behaviour

The user interface could work as follows:

Question 1 of 8

Is the vulnerable service exposed to the public internet?

[Yes] [No]

Selected: No

Risk contribution: 0 points

Why this matters: The service is not directly reachable from the internet.

[Back]

[Next]

For the next questions:

Is the vulnerable component enabled?

[Yes] [No]

Selected: Yes

Risk contribution: +2 points

Is authentication required to exploit the vulnerability?

[Yes] [No]

Selected: Yes

Risk contribution: 0 points

Does the system process sensitive or regulated data?

[Yes] [No]

Selected: Yes

Risk contribution: +2 points

The user should see the score contribution only if you want the process to be transparent. Alternatively, show the contributions only in the final assessment report.

Add uncertainty handling

A Yes/No answer is not always known. Add a third option:

[Yes] [No] [Unknown]

Recommended handling:

Answer	Treatment
Yes	Apply the defined positive or negative weight
No	Apply the defined alternative weight
Unknown	Do not assume safe; flag for review
Not applicable	Exclude the metric with a documented reason

For risk management, **Unknown should not normally be treated as No**. For example, if the organisation does not know whether the service is internet exposed, the system should produce:

```

Organisation Risk Score: Pending
Reason: Internet exposure has not been confirmed.
Required action: Validate AWS load balancer and security-group configuration.

```

You can also use a conservative rule:

```

Unknown = highest plausible risk value

```

However, this should be explicitly approved by the organisation's risk owner.

Recommended data structure

Store the question, answer, rule, evidence, and score contribution:

```

{
  "question_id": "internet_exposure",
  "question": "Is the vulnerable service exposed to the public internet?",
  "answer": "no",
  "score_rule": {
    "yes": 3,
    "no": 0,
    "unknown": "review_required"
  },
  "score_contribution": 0,
  "evidence_required": true,
  "evidence_reference": "AWS load balancer and security group configuration",
  "confirmed_by": "organisation-risk-owner",
  "confirmed_at": "2026-09-21T20:30:00+08:00"
}

```

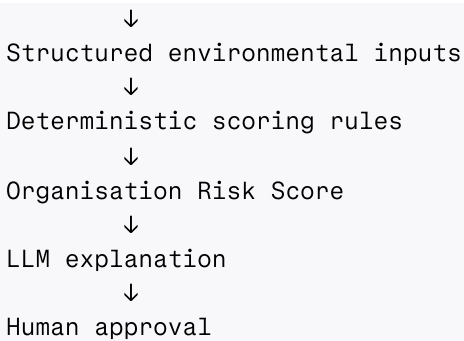
Best design for your project

I recommend this model:

```

Official NVD/Vendor CVSS
+
Organisation Yes/No questionnaire

```



The LLM should:

- Present the questions.
- Explain each question.
- Convert answers into structured fields.
- Identify missing or contradictory answers.
- Request evidence.
- Explain why the score differs from NVD or vendor scoring.

The deterministic scoring engine should:

- Apply the weights.
- Calculate the score.
- Assign the risk rating.
- Record the calculation.
- Prevent the LLM from changing the final score.

A suitable requirement is:

The system shall provide predefined Yes/No/Unknown questions for collecting environment-specific vulnerability information. Each answer shall be mapped to a documented scoring rule. The Organisation Risk Score shall be calculated deterministically from the confirmed answers, with the score contribution, evidence, calculation, and approval status retained for audit purposes.

✱✱

for all the cve, can we make a predefined question? what if the condition of the CVE is different?

No, you should not use exactly the same questions for every CVE. Use a **common core questionnaire** for all CVEs, then add **CVE-specific conditional questions** based on the vulnerability's attack conditions and affected technology.

CVSS itself follows this principle: Base metrics describe the vulnerability's intrinsic characteristics, while Environmental metrics adapt the assessment to the organisation's

particular environment and controls. ^[20]

Recommended question structure

```
Common questions
+
CVE-specific questions
+
Organisation-specific asset questions
↓
Final contextual assessment
```

1. Common questions

These can apply to almost every vulnerability:

- Is the affected component deployed in production?
- Is the component enabled and actively used?
- Is the affected asset internet-facing?
- Is authentication required?
- Does the asset process sensitive data?
- Is the asset business-critical?
- Is there a compensating control?
- Is a patch or mitigation available?
- Is exploitation currently detected or suspected?

These questions assess the organisation's environment.

2. CVE-specific questions

These should depend on the CVE's actual conditions.

For example, a vulnerability might require:

- A specific configuration option to be enabled.
- A particular protocol or port to be reachable.
- A malicious file to be opened.
- A local user account.
- A specific privilege level.
- A vulnerable feature to be enabled.
- A particular operating-system version.
- A specific input or API endpoint.

The system should ask those questions only when they are relevant.

Example: remote network vulnerability

Suppose the CVE can be exploited remotely over a network without authentication.

The system could ask:

Is the affected service reachable from an untrusted network?

[Yes] [No] [Unknown]

Is the vulnerable port exposed through a firewall or security group?

[Yes] [No] [Unknown]

Is the vulnerable feature enabled?

[Yes] [No] [Unknown]

Is the service internet-facing?

[Yes] [No] [Unknown]

If the organisation answers:

Untrusted network access: No

Vulnerable port exposed: No

Feature enabled: Yes

Internet-facing: No

The CVE remains technically severe, but its practical exploitability may be lower in that environment.

Example: client-side vulnerability

For a browser or document-processing vulnerability, internet exposure may not be the most relevant condition. Use questions such as:

Does the affected software process untrusted files or content?

[Yes] [No] [Unknown]

Can users open files from external sources?

[Yes] [No] [Unknown]

Is user interaction required for exploitation?

[Yes] [No] [Unknown]

Are endpoints protected by application isolation or sandboxing?

[Yes] [No] [Unknown]

Are affected users privileged administrators?

[Yes] [No] [Unknown]

Asking “Is the server internet-facing?” would be irrelevant or misleading for this type of CVE.

Example: privilege-escalation vulnerability

For a local privilege-escalation vulnerability:

```
Can an attacker obtain local access to the affected system?  
[Yes] [No] [Unknown]
```

```
Are unprivileged users allowed to log in?  
[Yes] [No] [Unknown]
```

```
Is the vulnerable binary installed and executable?  
[Yes] [No] [Unknown]
```

```
Does the system contain privileged service accounts?  
[Yes] [No] [Unknown]
```

```
Are endpoint privilege controls enabled?  
[Yes] [No] [Unknown]
```

Here, “internet-facing” may be less important than local access and privilege boundaries.

How the system chooses questions

Store a vulnerability condition profile with each CVE. The profile can be derived from the CVE description, CVSS vector, vendor advisory, CWE, affected product, and scanner information.

Example:

```
{  
  "cve_id": "CVE-2025-XXXX",  
  "vulnerability_type": "remote_code_execution",  
  "base_conditions": {  
    "attack_vector": "network",  
    "privileges_required": "none",  
    "user_interaction": "none",  
    "scope": "unchanged"  
  },  
  "required_conditions": [  
    "vulnerable_service_enabled",  
    "network_path_available"  
  ],  
  "question_templates": [  
    "Is the vulnerable service enabled?",  
    "Can an attacker reach the vulnerable service from an untrusted network?",  
    "Is the vulnerable port exposed through a firewall or security group?"  
  ]  
}
```

Another CVE might have a different profile:

```
{  
  "cve_id": "CVE-2025-YYYY",
```

```

    "vulnerability_type": "local_privilege_escalation",
    "base_conditions": {
      "attack_vector": "local",
      "privileges_required": "low",
      "user_interaction": "none"
    },
    "required_conditions": [
      "local_user_access",
      "vulnerable_binary_installed"
    ],
    "question_templates": [
      "Can an unprivileged user log in to the affected system?",
      "Is the vulnerable binary installed and executable?",
      "Are endpoint privilege controls enabled?"
    ]
  }
}

```

Use question templates, not manually written questions

Create a library of reusable condition templates:

Condition	Question template
Network attack vector	Can the vulnerable service be reached from an untrusted network?
Local attack vector	Can an unprivileged user obtain local access?
User interaction required	Must a user open a file, click a link, or perform an action?
No privileges required	Is the affected function accessible without authentication?
Specific feature required	Is the vulnerable feature or configuration enabled?
Sensitive data impact	Does the asset process sensitive or regulated information?
Availability impact	Would compromise interrupt a critical business service?
Compensating controls	Is the affected component protected by a control that prevents or detects exploitation?

The CVE profile selects the applicable templates.

Add a relevance check

Before displaying a question, the system should determine whether it is relevant:

Question relevance process:

1. Read the CVE technical conditions.
2. Extract the required exploit conditions.
3. Identify the affected asset and technology.
4. Match conditions to question templates.
5. Ask only relevant questions.
6. Allow the user to mark a question as Not Applicable.

Example:

```
{
  "question_id": "internet_exposure",
  "relevance": "required",
  "reason": "The CVE has Attack Vector: Network"
}
```

```
{
  "question_id": "user_opens_file",
  "relevance": "not_applicable",
  "reason": "The CVE does not require user interaction"
}
```

What if the CVE condition is different?

The system should not force an answer to an unrelated Yes/No question. Instead, it should support:

```
[Yes] [No] [Unknown] [Not Applicable]
```

Use the options as follows:

- **Yes:** The condition exists in the organisation's environment.
- **No:** The condition does not exist.
- **Unknown:** The organisation has not verified the condition.
- **Not Applicable:** The question does not apply to this CVE or asset.

For example:

```
Does a user need to open a malicious document?

[Yes] [No] [Unknown] [Not Applicable]
```

For a server-side network vulnerability, the correct answer may be **Not Applicable**, not No.

Scoring model

Separate the score into two parts:

Technical applicability

This determines whether the CVE's exploit conditions are present.

```
Exploit condition status:
- Confirmed present
- Confirmed absent
```

- Unknown
- Not applicable

Environmental impact

This determines the effect on the organisation:

Asset criticality
Data sensitivity
Production status
Business impact
Compensating controls
Exposure
Remediation availability

A simplified model might be:

[Organisation Risk

Base Technical Severity

\times

Applicability Factor

\times

Environmental Impact Factor

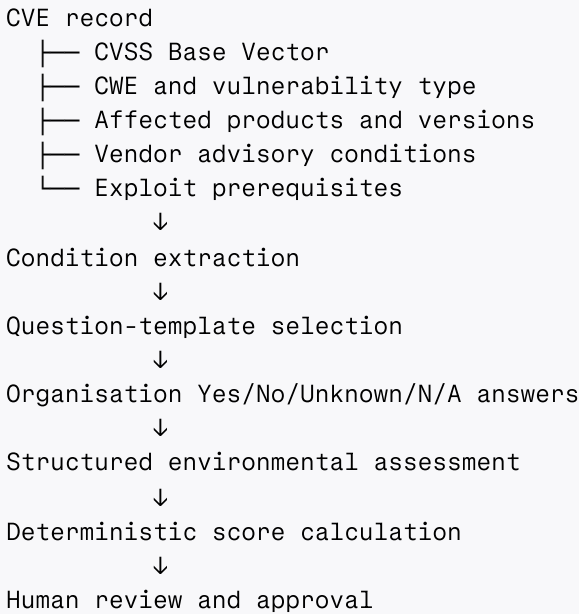
]

Example factors:

Condition	Factor
Exploit conditions confirmed	1.0
Exploit conditions partially confirmed	0.75
Exploit conditions unknown	1.0 plus review flag
Exploit condition confirmed absent	0.25
Vulnerable component disabled	0.1
Strong compensating controls	0.7
Critical production asset	1.0
Low-value test asset	0.3

Do not reduce the score merely because something is unknown. Instead, calculate the score conservatively and mark it for validation.

Best architecture



A suitable requirement would be:

The system shall maintain a common set of organisation-environment questions and a library of CVE-specific question templates. For each CVE, the system shall select questions based on the vulnerability's attack vector, privileges, user interaction, affected technology, exploit prerequisites, and vendor-described conditions. The system shall not present irrelevant questions and shall support Yes, No, Unknown, and Not Applicable responses.

The Organisation Risk Score shall be calculated using the confirmed applicability of the CVE's exploit conditions, the criticality and impact of the affected asset, and validated compensating controls. The original CVSS Base Score shall remain unchanged and shall be displayed separately.

✱

for the common vulnerability, how do we make the weightage of the score

For common vulnerabilities, use a **standard weighted model** with the same categories for every CVE. The CVE-specific conditions can modify the questions, but the main weight categories remain stable.

A practical starting model is:

[Organisation Risk Score

$$0.30T + 0.30E + 0.20B + 0.20C$$

]

Where:

- T = technical severity and exploitability.
- E = environmental exposure and reachability.
- B = business and asset impact.
- C = current exploitation and threat context.

This avoids allowing the NVD CVSS score to dominate the whole assessment. CVSS Environmental metrics similarly allow an organisation to adjust the assessment based on asset importance, security requirements, and environmental conditions. [\[35\]](#) [\[36\]](#)

Recommended weighting

Category	Weight	What it measures
Technical severity	30%	CVSS severity and technical exploitability
Exposure and reachability	25%	Internet exposure, network access, segmentation
Business impact	25%	Asset criticality, data sensitivity, operational impact
Threat and exploitation	20%	Active exploitation, public exploit, exploit likelihood
Total	100%	

This is a good general-purpose starting point. It reflects the principle that real risk depends on more than raw CVSS: exploitation evidence, exposure, business impact, and technical severity should all be considered. [\[37\]](#)

Convert each category to 0–100

Do not calculate directly from Yes/No values such as Yes = 1 and No = 0 without defining what each answer means. Instead, convert answers into category scores.

Technical severity: 30%

Use the highest available technical score:

Condition	Technical score
CVSS 9.0–10.0	100
CVSS 7.0–8.9	80
CVSS 4.0–6.9	60

Condition	Technical score
CVSS 0.1–3.9	30
CVSS 0.0	0

You can use the exact CVSS score instead:

$$T = \frac{\text{CVSS Base Score}}{10} \times 100$$

For a CVSS score of 8.0:

$$T = \frac{8.0}{10} \times 100 = 80$$

Exposure and reachability: 25%

Question	Answer	Points
Is the affected service internet-facing?	Yes	40
Is it reachable from an untrusted network?	Yes	25
Is the vulnerable port or API exposed?	Yes	20
Is the asset isolated or segmented?	Yes	-15
Is the component disabled?	Yes	-30

Clamp the final category between 0 and 100:

$$E = \max(0, \min(100, \text{exposure points}))$$

Example:

```

Internet-facing: No      0
Untrusted network access: No  0
Vulnerable port exposed: No  0
Network segmentation: Yes  -15
-----
Exposure score:          0

```

Do not allow a strong control to produce a negative risk score.

Business impact: 25%

Question	Answer	Points
Is the asset business-critical?	Yes	35
Is it a production system?	Yes	20
Does it process sensitive data?	Yes	25
Could compromise cause major service disruption?	Yes	20

Question	Answer	Points
Is it a test or development system?	Yes	-20

Example:

```

Business-critical: Yes          35
Production: Yes                20
Sensitive data: Yes            25
Major service disruption possible: No    0
-----
Business impact score:          80

```

Threat and exploitation: 20%

Question	Answer	Points
Is the CVE in CISA KEV or another trusted exploited-vulnerability list?	Yes	50
Is there confirmed active exploitation?	Yes	30
Is public exploit code available?	Yes	20
Is exploitation highly automated?	Yes	15
Is the exploit difficult and not publicly available?	Yes	-15

CISA-style prioritisation increasingly considers public accessibility, known exploitation, automation, and the level of control obtained after exploitation rather than relying only on severity. [\[38\]](#) [\[39\]](#)

Example calculation

Assume:

```

CVE CVSS score:          8.0
Internet-facing:         No
Untrusted network access: No
Network segmentation:    Yes
Production system:       Yes
Business-critical:       Yes
Sensitive data:          Yes
Known exploited:         No
Public exploit:          No

```

Category scores:

```

Technical severity: 80
Exposure:          0
Business impact:   80
Threat context:    0

```

Weighted result:

[Risk Score

(80×0.30)

+

(0×0.25)

+

(80×0.25)

+

(0×0.20)

]

$$\text{Risk Score} = 24 + 0 + 20 + 0 = 44$$

Therefore:

Score	Rating
0-24	Low
25-49	Medium
50-74	High
75-100	Critical

Result:

Organisation Risk Score: 44
Organisation Risk Rating: Medium

The result can be displayed alongside the technical score:

NVD CVSS Base Score: 8.0 – High
Organisation Risk Score: 44/100 – Medium

This does not mean the vulnerability is technically less severe. It means the current environment reduces practical exposure.

Yes/No answers should use question-specific weights

Do not use one universal rule such as:

Yes = +10
No = 0

Instead, define the meaning of Yes for each question:

```
{
  "question_id": "internet_facing",
  "question": "Is the affected service exposed to the public internet?",
  "category": "exposure",
  "yes_points": 40,
  "no_points": 0,
  "unknown_action": "review_required"
}
```

```
{
  "question_id": "sensitive_data",
  "question": "Does the affected asset process sensitive data?",
  "category": "business_impact",
  "yes_points": 25,
  "no_points": 0,
  "unknown_action": "review_required"
}
```

```
{
  "question_id": "network_segmentation",
  "question": "Is the affected asset protected by effective network segmentation?",
  "category": "exposure",
  "yes_points": -15,
  "no_points": 0,
  "unknown_action": "review_required"
}
```

Handle Unknown separately

Add Unknown to every important question:

```
[Yes] [No] [Unknown] [Not Applicable]
```

Recommended behaviour:

- **Yes:** Apply the predefined weight.
- **No:** Apply zero or the predefined alternative weight.
- **Unknown:** Calculate provisionally but flag the assessment for review.
- **Not Applicable:** Exclude the question and record the reason.

For example:

```
{
  "answer": "unknown",
  "score_contribution": null,
  "status": "requires_validation",
}
```

```
"required_evidence": "AWS load balancer and security-group configuration"
}
```

Avoid treating Unknown as No, because that could artificially reduce the risk score.

Apply override rules

Some conditions should override the normal weighted score:

```
If active exploitation is confirmed:
    Minimum rating = High

If active exploitation is confirmed and the asset is internet-facing:
    Rating = Critical

If the vulnerable component is confirmed disabled:
    Do not automatically set risk to Low;
    require validation that it is not reachable or loaded.

If a critical asset processes regulated data:
    Minimum rating = High
```

This prevents a low weighted score from hiding an urgent situation.

Recommended final model

1. Calculate Technical Severity score.
2. Calculate Exposure score.
3. Calculate Business Impact score.
4. Calculate Threat Context score.
5. Apply the category weights.
6. Apply mandatory escalation rules.
7. Identify unknown or unverified answers.
8. Produce the Organisation Risk Score.
9. Require human approval for High and Critical results.

A suitable requirement is:

The system shall calculate the Organisation Risk Score using a documented weighted model consisting of technical severity, environmental exposure, business impact, and threat context. Each Yes/No response shall map to a question-specific score contribution. Unknown and Not Applicable responses shall be handled separately and shall not be silently treated as No. The system shall apply predefined escalation rules for active exploitation, internet-facing critical assets, and other organisation-defined conditions.

i need a LLM in play, how do we include that

Include the LLM as a **contextual assessment assistant**, not as the final scoring authority. The LLM should select and explain questions, interpret the organisation's Yes/No answers, identify missing evidence, and produce an auditable rationale; a deterministic rules engine should calculate the final Organisation Risk Score.

NIST recommends defining and documenting human and AI responsibilities, while OWASP guidance recommends strict output schemas, least privilege, human approval, and deterministic logic where AI is not required. ^[51] ^[52]

Proposed architecture

```
graph TD; A[CVE data and vendor advisories] --> B[LLM vulnerability analyst]; B --> C[CVE condition profile]; C --> D[Question template selector]; D --> E[Organisation answers Yes / No / Unknown / N/A]; E --> F[LLM answer validator and evidence analyst]; F --> G[Structured assessment JSON]; G --> H[Deterministic scoring engine]; H --> I[LLM explanation generator]; I --> J[Human approval]; J --> K[Final risk record];
```

What the LLM does

1. Analyse the CVE

The LLM reads the CVE description, CVSS vector, CWE, affected products, vendor advisory, and exploit prerequisites.

It extracts facts such as:

```
{
  "attack_vector": "network",
  "privileges_required": "none",
  "user_interaction": "none",
  "affected_component": "web service",
  "required_conditions": [
    "vulnerable_service_enabled",
```

```
"network_path_available",
"affected_version_deployed"
]
}
```

The LLM should cite the source for each extracted condition and mark uncertain information as unknown.

2. Select relevant questions

The LLM maps the extracted conditions to predefined question templates.

```
{
  "selected_questions": [
    {
      "question_id": "service_enabled",
      "question": "Is the vulnerable service enabled?",
      "reason": "The CVE requires the affected service to process requests."
    },
    {
      "question_id": "network_reachability",
      "question": "Can the vulnerable service be reached from an untrusted network?"
      "reason": "The CVE has a network attack vector."
    },
    {
      "question_id": "internet_exposure",
      "question": "Is the vulnerable service exposed to the public internet?",
      "reason": "Public exposure increases environmental exploitability."
    }
  ]
}
```

The LLM can recommend the questions, but your application should validate that each question belongs to an approved template library.

3. Explain the questions

The LLM can provide user-friendly explanations:

```
This question is relevant because the vulnerability can be triggered through network
```

4. Interpret the answers

The organisation answers only through the structured UI:

```
Is the vulnerable service exposed to the public internet?

[Yes] [No] [Unknown] [Not Applicable]
```

The LLM then converts the answers into structured values:

```
{
  "internet_exposed": false,
  "network_reachability": false,
  "service_enabled": true,
  "answer_confidence": "high",
  "evidence_required": false
}
```

If the answer conflicts with the CVE conditions, the LLM should flag it:

The vulnerability requires a network-accessible service, but the organisation reports

5. Identify evidence gaps

The LLM should ask for evidence only when appropriate:

You selected “No” for internet exposure. Please provide or confirm one of the following:

- Cloud load-balancer configuration.
- Firewall or security-group rule.
- Network architecture record.
- Vulnerability scanner reachability result.

The organisation can upload evidence or select an existing record. Avoid allowing the LLM to treat unsupported text as proof.

6. Generate the explanation

After scoring, the LLM can generate a readable explanation from the verified structured inputs:

The NVD CVSS Base Score is 8.0 because the vulnerability is remotely exploitable and

The LLM should explain the result, not change it.

What the deterministic engine does

The scoring engine should receive only validated structured data:

```
{
  "technical_score": 80,
  "internet_exposed": false,
  "untrusted_network_access": false,
  "service_enabled": true,
  "production_asset": true,
  "asset_criticality": "high",
  "sensitive_data": true,
  "known_exploitation": false,
  "public_exploit": false,
  "compensating_controls": [
```

```
    "network_segmentation",
    "security_groups",
    "waf"
  ]
}
```

It then applies fixed rules:

```
risk_score = (
    technical_score * 0.30
  + exposure_score * 0.25
  + business_impact_score * 0.25
  + threat_score * 0.20
)
```

The LLM must not be able to alter the weights, thresholds, escalation rules, or final result through a prompt.

Example end-to-end interaction

Step 1: CVE analysis

LLM:

This CVE is a network-based vulnerability. It does not require authentication or user

Step 2: Organisation questionnaire

Is the vulnerable service enabled?

[Yes] [No] [Unknown]

Can the service be reached from an untrusted network?

[Yes] [No] [Unknown]

Is the service exposed to the public internet?

[Yes] [No] [Unknown]

Is the affected asset deployed in production?

[Yes] [No] [Unknown]

Does it process sensitive data?

[Yes] [No] [Unknown]

Step 3: Structured confirmation

Please confirm the assessment:

Service enabled: Yes

Untrusted network access: No

Internet exposed: No

Production asset: Yes
Sensitive data: Yes

[Edit answers] [Confirm assessment]

Step 4: Deterministic calculation

Technical severity: 80
Exposure: 0
Business impact: 80
Threat context: 0

Organisation Risk Score: 44/100
Organisation Risk Rating: Medium

Step 5: LLM explanation

The vulnerability has High technical severity, but the environmental risk is Medium

Use separate LLM roles

For a stronger design, use separate logical roles even if they run on the same model:

LLM role	Responsibility
Vulnerability analyst	Extract CVE conditions and technical facts
Question selector	Select relevant approved questions
Assessment assistant	Explain questions and collect answers
Evidence reviewer	Identify missing or conflicting evidence
Explanation generator	Explain the calculated score
Quality checker	Detect unsupported claims and contradictions

The scoring engine remains outside the LLM.

Recommended output schema

Force the LLM to return JSON rather than unrestricted text:

```
{
  "cve_id": "CVE-2025-XXXX",
  "technical_analysis": {
    "attack_vector": "network",
    "privileges_required": "none",
    "user_interaction": "none",
    "required_conditions": [
      "service_enabled",
      "network_path_available"
    ]
  }
}
```

```

    ],
    "confidence": 0.92,
    "evidence": [
      {
        "source": "vendor_advisory",
        "claim": "The vulnerable service must process a network request."
      }
    ]
  },
  "questions": [
    {
      "question_id": "service_enabled",
      "text": "Is the vulnerable service enabled?",
      "answer_type": "yes_no_unknown",
      "required": true
    }
  ],
  "assessment": {
    "status": "awaiting_organisation_response"
  }
}

```

Your application should reject responses that:

- Contain unknown question IDs.
- Omit required fields.
- Include a score that was not calculated by the scoring engine.
- Include unsupported claims.
- Try to execute an unauthorised tool or action.

Strict output validation is important because model output should be treated as untrusted application input. [\[53\]](#) [\[54\]](#)

Human approval points

Require human confirmation at three stages:

1. Question confirmation

Confirm that the selected questions are relevant.

2. Environment confirmation

Confirm that the extracted Yes/No answers accurately represent the environment.

3. Final risk approval

Approve or reject the calculated Organisation Risk Score and explanation.

For example:

The calculated score is 44/100 – Medium.

[Approve assessment] [Request changes] [Escalate for review]

High-risk actions should not be performed automatically. The LLM should not patch systems, change firewall rules, close findings, or mark a CVE as accepted without separate authorisation.

Suggested requirement

- The system shall use an LLM to analyse vulnerability information, identify exploit prerequisites, select relevant questions from an approved question-template library, explain the questions to the organisation, detect incomplete or contradictory answers, and generate an evidence-based explanation of the calculated risk.
- The LLM shall return structured output that is validated by application code. The LLM shall not directly determine the final Organisation Risk Score, modify scoring weights, override escalation rules, or approve a risk decision.
- The Organisation Risk Score shall be calculated by a deterministic scoring engine using confirmed organisation responses and validated evidence. The final assessment shall require human review and shall retain the CVE data, LLM output, organisation answers, evidence, score calculation, prompt/model version, and approval record for audit purposes.

This gives you a meaningful LLM role while keeping the actual risk decision explainable, repeatable, and auditable.



Suggest me a scoring weight for the yes and no

Yes. For a practical first version, use a 100-point Organisation Risk Score and assign a positive or zero weight to each Yes/No question. The weights should reflect exploitability, exposure, business impact, and evidence of exploitation—not simply the number of questions answered “Yes.” NIST guidance supports combining likelihood of exploitation, impact, and asset criticality rather than relying on one metric. ^[66] ^[67]

Recommended baseline weights

Question	Yes	No	Category
Is the vulnerable asset internet-facing?	+20	0	Exposure
Can an untrusted network reach the vulnerable service?	+15	0	Exposure
Is the vulnerable component enabled and actively used?	+10	0	Applicability
Is authentication not required for exploitation?	+10	0	Exploitability
Is user interaction not required?	+5	0	Exploitability
Is public exploit code available?	+10	0	Threat
Is the CVE listed in the CISA KEV catalogue or confirmed exploited?	+20	0	Threat
Is the affected asset business-critical?	+10	0	Business impact

Question	Yes	No	Category
Does the asset process sensitive or regulated data?	+10	0	Business impact
Could exploitation cause a major outage or integrity loss?	+10	0	Business impact
Is the asset protected by effective compensating controls?	0	+0	Control adjustment
Is the vulnerable component disabled?	0	+0	Applicability

The positive weights above total more than 100 because not every question will apply to every CVE. Calculate the raw score and cap it at 100:

```
raw_score = sum(score_contributions)
organisation_score = min(raw_score, 100)
```

For controls and disabled components, use negative adjustments rather than “Yes = positive risk”:

Question	Yes	No
Is effective network segmentation in place?	-10	0
Is a WAF or equivalent control blocking the exploit path?	-5	0
Is the vulnerable component disabled?	-20	0
Is the vulnerable asset isolated from sensitive systems?	-5	0
Is a tested mitigation already applied?	-10	0

Apply the floor as well:

```
organisation_score = max(0, min(raw_score, 100))
```

Recommended rating bands

Score	Rating	Suggested interpretation
0–24	Low	Limited practical exposure or impact
25–49	Medium	Requires planned remediation
50–74	High	Prioritised remediation required
75–100	Critical	Urgent remediation or incident investigation

Example

Assume the organisation answers:

```
Internet-facing:           No
Untrusted network reachable: No
Component enabled:         Yes
```

Authentication not required:	Yes
User interaction not required:	Yes
Public exploit available:	No
Known exploited/KEV:	No
Business-critical asset:	Yes
Sensitive data:	Yes
Major outage possible:	Yes
Network segmentation:	Yes
Component disabled:	No

Calculation:

Component enabled:	+10
Authentication not required:	+10
User interaction not required:	+5
Business-critical asset:	+10
Sensitive data:	+10
Major outage possible:	+10
Network segmentation:	-10

Organisation Risk Score:	45
Organisation Risk Rating:	Medium

The technical CVSS score should remain separate:

NVD CVSS Base Score: 9.8 – Critical
Organisation Risk Score: 45/100 – Medium

The difference means the vulnerability is technically severe, but the current environment reduces practical exposure.

Treat important Yes answers as overrides

Some answers should not merely add points. They should trigger a minimum rating:

If confirmed exploited/KEV and present:
minimum rating = High

If confirmed exploited/KEV and internet-facing:
minimum rating = Critical

If internet-facing and no authentication is required:
minimum rating = High

If the asset is critical and processes regulated data:
minimum rating = High

If the vulnerable component is confirmed disabled and unreachable:
maximum rating = Medium, unless exploitation is already detected

This is particularly important for known-exploited vulnerabilities. Recent risk-based prioritisation models emphasise exposure, known exploitation, exploit automation, and technical impact rather than CVSS alone.^[68] ^[69]

How to handle No

A No answer should mean **the risk-increasing condition is absent**. For example:

```
Is the asset internet-facing?  
  Yes = +20  
  No  = 0
```

But for a control question:

```
Is effective network segmentation in place?  
  Yes = -10  
  No  = 0
```

Avoid assigning a negative score to every No. Whether No reduces risk depends on the wording of the question.

Use clear question wording:

```
Risk condition:  
Is the asset internet-facing?  
Yes = risk increases.  
  
Control condition:  
Is effective network segmentation in place?  
Yes = risk decreases.
```

Include Unknown and Not Applicable

Your UI should provide four choices:

```
[Yes] [No] [Unknown] [Not Applicable]
```

Recommended scoring:

Answer	Default treatment
Yes	Apply the defined weight
No	Apply zero or the defined control adjustment
Unknown	No silent reduction; mark assessment for review
Not Applicable	Exclude from scoring and record the reason

For an unknown answer, you can either:

Option A: Calculate a provisional score and flag it.
Option B: Use the higher-risk value until evidence is provided.

For a security assessment, I recommend Option A:

```
{
  "organisation_score": 45,
  "assessment_status": "provisional",
  "unknown_questions": [
    "Can an untrusted network reach the vulnerable service?"
  ],
  "human_review_required": true
}
```

Include the LLM safely

The LLM can recommend the answer and explain the evidence, but the rules engine applies the weight:

```
LLM:
Based on the AWS security-group evidence, internet exposure appears to be No.
Confidence: 0.91
Evidence: sg-012345

Rules engine:
internet_facing = No
score contribution = 0
```

For each answer, save:

```
{
  "question_id": "internet_facing",
  "answer": "no",
  "weight_applied": 0,
  "reason": "No public route to the affected service",
  "evidence": "AWS load balancer and security-group configuration",
  "llm_confidence": 0.91,
  "human_confirmed": true
}
```

The LLM should never return:

```
{
  "organisation_risk_score": 82
}
```

Instead, it should return the assessment inputs:

```
{
  "internet_facing": false,
  "component_enabled": true,
  "sensitive_data": true,
  "evidence_gaps": []
}
```

Then your scoring function produces the score.

Suggested implementation

```
WEIGHTS = {
    "internet_facing": 20,
    "untrusted_network_reachable": 15,
    "component_enabled": 10,
    "authentication_not_required": 10,
    "user_interaction_not_required": 5,
    "public_exploit_available": 10,
    "known_exploited": 20,
    "business_critical": 10,
    "sensitive_data": 10,
    "major_outage_possible": 10,
}

CONTROL_ADJUSTMENTS = {
    "network_segmentation": -10,
    "waf_blocks_exploit": -5,
    "component_disabled": -20,
    "asset_isolated": -5,
    "tested_mitigation": -10,
}

def calculate_score(answers):
    score = 0
    unknown_questions = []

    for question, weight in WEIGHTS.items():
        answer = answers.get(question)

        if answer == "yes":
            score += weight
        elif answer == "unknown":
            unknown_questions.append(question)

    for control, adjustment in CONTROL_ADJUSTMENTS.items():
        if answers.get(control) == "yes":
            score += adjustment

    score = max(0, min(score, 100))

    if score <= 24:
        rating = "Low"
    elif score <= 49:
        rating = "Medium"
```

```

elif score <= 74:
    rating = "High"
else:
    rating = "Critical"

if answers.get("known_exploited") == "yes" and answers.get("internet_facing") ==
    rating = "Critical"
elif answers.get("known_exploited") == "yes" and rating == "Low":
    rating = "High"

return {
    "score": score,
    "rating": rating,
    "unknown_questions": unknown_questions,
    "status": "provisional" if unknown_questions else "confirmed"
}

```

These weights are a defensible prototype, not a universal industry standard. You should calibrate them against your organisation's incident history, asset tiers, remediation SLAs, and risk appetite. CVSS Environmental scoring is another valid approach if you want closer compatibility with the CVSS specification; keep that score separate from any custom weighted Organisation Risk Score. ^[70] ^[71]



1. Information-for-Hein.docx
2. image-2.jpg
3. Information-for-Hein.docx
4. Information-for-Hein.docx
5. <https://www.first.org/cvss/v3.1/user-guide>
6. https://www.first.org/cvss/v3-1/cvss-v31-specification_r1.pdf
7. <https://www.oracle.com/security-alerts/cvssscoringsystem.html>
8. https://en.wikipedia.org/wiki/Common_Vulnerability_Scoring_System
9. <https://www.sophos.com/en-us/blog/prioritizing-patching-a-deep-dive-into-frameworks-and-tools-part-1-cvss>
10. <https://www.first.org/cvss/calculator/4.0>
11. <https://www.first.org/cvss/v4.0/user-guide>
12. <https://github.com/syselement/blog/blob/main/cyber-everything/generic/cvss3.1.md>
13. <https://blog.syselement.com/home/cyber-everything/generic/cvss3.1>
14. <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?name=CVE-2021-44746&vector=AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N&version=3.1&source=NIST>
15. https://www.itu.int/rec/dologin_pub.asp?lang=e&id=T-REC-X.1521-201603-1!!PDF-E&type=items
16. https://docs.qualys.com/en/vm/latest/setup/cvss_scoring.htm
17. <https://arxiv.org/html/2308.15259v2>
18. <https://www.first.org/cvss/specification-document>
19. https://docs.qualys.com/en/vm/10.30.0.0/setup/cvss_scoring.htm

20. <https://www.first.org/cvss/v3.1/specification-document>
21. <https://www.securityweek.com/first-announces-cvss-version-31/>
22. <https://helm.docs.medcrypt.com/prioritize-vulnerabilities/understand-issue-severity-level/understand-the-cvss-vulnerability-scoring-system>
23. https://www.iaeng.org/publication/WCECS2016/WCECS2016_pp170-175.pdf
24. https://www.first.org/cvss/v3-1/cvss-v31-specification_r1.pdf
25. <https://www.first.org/cvss/specification-document>
26. <https://www.first.org/cvss/v4.0/user-guide>
27. <https://nvd.nist.gov/vuln-metrics/cvss/v4-calculator>
28. https://access.redhat.com/security/risk_based_approach_cve_assessments_regulated_environments
29. <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>
30. https://csrc.nist.gov/files/pubs/ir/7946/final/docs/draft_nistir_7946.pdf
31. <https://nvd.nist.gov/vuln-metrics/cvss/v2-calculator>
32. <https://www.first.org/cvss/calculator/3.1>
33. <https://www.first.org/cvss/v4-0/cvss-v40-specification.pdf>
34. <https://www.first.org/cvss/v4.0/implementation-guide>
35. <https://www.first.org/cvss/v4.0/specification-document>
36. <https://www.first.org/cvss/v3.1/specification-document>
37. <https://inventivehq.com/blog/how-to-prioritize-vulnerabilities-for-remediation>
38. <https://stackarmor.com/cisa-bod-26-04-implementation-guide/>
39. <https://govciomedia.com/cisa-overhauls-federal-cyber-risk-model-with-new-directive/>
40. <https://nhimg.org/articles/cisa-risk-based-vulnerability-prioritization-changes-appsec-triage/>
41. <https://inventivehq.com/blog/vulnerability-management-patch-prioritization-workflow>
42. <https://www.first.org/cvss/specification-document>
43. <https://www.first.org/cvss/v4-0/cvss-v40-specification.pdf>
44. <https://www.first.org/cvss/v3.1/user-guide>
45. https://www.first.org/cvss/v3-1/cvss-v31-specification_r1.pdf
46. <https://www.first.org/cvss/v4.0/implementation-guide>
47. <https://apps.dtic.mil/sti/pdfs/AD1108129.pdf>
48. <https://csrc.nist.gov/CSRC/media/Projects/Security-Content-Automation-Protocol/documents/docs/2008-conf-presentations/scapTutorial/CVSS-Tutorial-20080919.pdf>
49. <https://www.soa.org/globalassets/assets/files/resources/research-report/2020/quantification-cyber-risk.pdf>
50. <https://ocsecurityaudit.com/prioritize-cisa-known-exploited-vulnerabilities/>
51. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>
52. <https://docs.aws.amazon.com/prescriptive-guidance/latest/agent-ai-security/owasp-top-ten.html>
53. <https://www.csoonline.com/article/575497/owasp-lists-10-most-critical-large-language-model-vulnerabilities.html>
54. <https://www.wiz.io/academy/ai-security/owasp-llm-top-10>

55. <https://genai.owasp.org/llm-top-10/>
56. <https://hackerdna.com/blog/owasp-llm-top-10>
57. <https://www.toolsmart.ai/blog/owasp-top-10-for-llm-applications/>
58. <https://www.articsledge.com/post/owasp-top-10-for-llm-applications>
59. <https://deepstrike.io/blog/owasp-llm-top-10-vulnerabilities>
60. <https://www.lasso.security/blog/owasp-top-10-llm-vulnerabilities-security-checklist>
61. <https://www.nist.gov/itl/ai-risk-management-framework>
62. <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>
63. <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>
64. <https://www.reversinglabs.com/blog/owasp-top-10-for-llm-apps-excessive-agency>
65. <https://arxiv.org/html/2512.06781v1>
66. https://essay.utwente.nl/fileshare/file/108115/Dudar_BA_EEMCS.pdf
67. <https://vulnerabilityinstitute.org/glossary/nist-sp-800-40>
68. <https://www.insideprivacy.com/cybersecurity-2/cisa-releases-binding-operational-directive-on-prioritizing-security-updates-based-on-risk/>
69. <https://industrialcyber.co/cisa/cisa-bod-26-04-directs-agencies-to-prioritize-exploited-vulnerabilities-and-assess-compromise-before-patching/>
70. <https://www.first.org/cvss/v3.1/specification-document>
71. <https://secportal.io/blog/cvss-scoring-explained>
72. <https://vulert.com/blog/cisa-kev-catalog-vulnerability-prioritization/>
73. <https://csrc.nist.rip/library/alt-SP800-40v2.pdf>
74. <https://secportal.io/frameworks/nist-sp-800-40>
75. https://www.first.org/cvss/v3-1/cvss-v31-specification_r1.pdf
76. <https://www.first.org/cvss/specification-document>
77. <https://www.first.org/cvss/v4.0/user-guide>
78. <https://arxiv.org/html/2512.06781>
79. <https://securityarsenal.com/blog/cisa-vulnerability-review-fy2024-2025-why-known-exposed-vulnerabilities-still-drive-most-compromises-a-defenders-prioritization-guide>
80. <https://warnerchad.medium.com/cvss-scores-in-cyber-threat-intelligence-bbc059a1df2c>